STRIDE ISP 6.1 – RS.MA

Incident Management

Version [2.0]

Purpose:

This document defines the Stride standards related to Response Planning.

Scope and Applicability

These policies and standards apply to all Stride-owned technology and business operations.

All workforce members and their respective facilities supporting Stride business operations, technology, or both, wherever Stride data is stored or processed, including any third party contracted by Stride to handle, process, transmit, store, or dispose of Stride data are subject to the requirements of this document.

All data, systems, activities, and assets owned, leased, controlled, or used by Stride, its agents, contractors, or other business partners on behalf of Stride are within the scope of the requirements of this document.

The requirements outlined in this document apply where technically feasible and commercially reasonable, as determined by executive management. Any exceptions to these standards must be requested using the approved workflow and remain documented until compliance has been achieved. Exceptions are only granted temporarily for periods of up to one calendar year.

Definitions

All definitions are located within Stride - ISP 1.2 – IT Policy Definitions.

Any inquiries regarding terminology or clarity may be directed to Stride's Information Security Team for assistance.

Publication Owners

Johnny Burns – Point of Contact, Content Coordinator & Author

Jen Havenner – Business Owner

Mark Williams – Executive Sponsor

Document Control

This document may contain proprietary, confidential, or sensitive information owned wholly by Stride Inc. Any distribution of the information contained within this document, in whole or in part, outside of Stride or its subsidiary entities requires the approval of the Executive Sponsor.

This document will be reviewed at least annually and re-issued when revisions are necessary. Any changes introduced in the most recent version are itemized below. Obsolete copies should be destroyed or archived upon the release of the newest version.

Implementation and Compliance

All business units are required to comply with any changes applied to the most recent version of this publication within 90 days from the date of publication.

Change History

Version	Date of Change	Summary of Change(s)
1.0	06/15/2022	Initial Release and Publication
1.1	12/01/2022	- Added Change History - Updated and/or redacted language for clarity where necessary
1.2	03/17/2023	- Updated approvals section
1.3	01/01/2024	- Updated Purpose/Scope/Document Control/Implementation and Compliance - Changed formatting to new standard - Changed document images
2.0	02/17/2025	- Updated Policy to match NIST 2.0 Release Changes - Updated Publication Owners
2.0	02/27/2025	- Published

INCIDENT MANAGEMENT STANDARDS

Policy on Response Planning:

Responses to detected cybersecurity incidents are managed.

RS.MA-01: RESPONSE PLAN EXECUTION

The incident response plan is executed in coordination with relevant third parties once an incident is declared.

Standards:

- Stride's response plans are in place and executed during or after an incident, including coordination with relevant third parties and engagement of third-party incident support services.

- Stride utilizes a Crisis Management Plan to determine response plan activation criteria which describe conditions that must be met before activation of a Response Plan is executed.

    - Personnel requiring access to Stride's Crisis Management Plan and Response Plans may do so via a central repository which allows authorized personnel to view the plans when needed.

    - A stakeholder/member of executive leadership who requires notification of plan activation is documented.

    - Roles and responsibilities are documented within the Response Plans.

    - Organizations that require notification of plan activation are documented.

    - Special considerations and/or arrangements for handling information assets in the event of plan activation are documented.

    - Criteria for activation may be based on:

        - Extent of any damage to the system (e.g., physical, operational, or cost).

        - Criticality of the system to the organization's mission (e.g., critical infrastructure protection asset).

        - Expected duration of the outage lasting longer than the RTO.

- Clearly define how the incident response plan integrates with the overall business continuity plan to ensure seamless transition and coordination.
    - Define specific recovery steps that should align with the BCP.
- Elaborate on internal and external communication protocols during incident response.
    - Define communication channels and escalation paths.
    - Detail communication templates for different scenarios (e.g., internal communications, public relations).
- Detail how incidents are detected, reported, and escalated.
- Specify criteria for declaring incidents and initiating the response plan.
- Include a detailed process for conducting post-incident reviews and analysis.
- Establish mechanisms for documenting lessons learned and applying improvements to the response plans.
- Include a schedule and process for regular training and awareness programs for personnel involved in incident response.
- Conduct regular tabletop exercises and simulations to test the response plans.
- Ensure the response plans comply with relevant, regulatory, and contractual obligations.
- Document procedures for preserving evidence and ensuring chain of custody.

References:

- Additional guidance may be found in NIST SP 800-34 – Contingency Planning Guide for Federal Information Systems
- Refer to the Stride Security Operations Incident and Crisis Management Guidelines for additional information
- CIS Controls v8.0: 17.4
- CRI Profile v2.0: RS.MA-01

- CRI Profile v2.0: RS.MA-01.01
- CSF v1.1: RS.RP-1
- CSF v1.1: RS.CO-4

RS.MA-02: INCIDENT TRIAGE

Incident reports are triaged and validated.

Standards:

- Stride's incident reports are systematically triaged to assess their urgency and impact.
    - Incidents are categorized based on predefined criteria (e.g., severity, potential impact on operations, data integrity, and confidentiality).
    - An Incident Response Team (IRT) is responsible for initial assessment and prioritization of incident reports.
    - A central repository is used to log all incident reports and their triage statuses.
- Each incident report undergoes a thorough validation process to ensure accuracy and completeness.
    - Incident reports are cross-checked with multiple sources to verify the reported information.
    - False positives are identified and filtered out to avoid unnecessary resource allocation.
    - In cases of ambiguous or incomplete information, follow-up actions are defined to gather the required data.
- Relevant stakeholders are notified promptly based on the triage outcomes and validation results.
    - Notification protocols are documented, specifying when and how stakeholders are informed.
    - Different levels of notification are defined based on incident severity and potential impact.

- Comprehensive documentation is maintained throughout the triage and validation processes.
    - Incident reports, triage statuses, validation results, and follow-up actions are logged systematically.
    - Audit trails are maintained to track the timeline and actions taken during the triage and validation phases.
- The triage and validation processes are regularly reviewed and improved based on lessons learned.
    - Post-incident reviews include an analysis of the triage and validation steps to identify areas for improvement.
    - Feedback loops are established to incorporate insights from incident handling into the triage and validation processes.
- Personnel involved in the triage and validation of incident reports receive regular training.
    - Training sessions cover incident classification, validation techniques, and effective communication protocols.
    - Simulated incident exercises are conducted to test the triage and validation processes.
- Ensure that the triage and validation processes comply with relevant legal, regulatory and contractual requirements.
    - Procedures for preserving evidence and ensuring the chain of custody are documented and followed.
    - Incident reporting aligns with industry standards and regulatory guidelines.

References:

- CRI Profile v2.0: RS.MA-02
- CRI Profile v2.0: RS.MA-02.01
- CSF v1.1: RS.AN-1
- CSF v1.1: RS.AN-2

RS.MA-03: INCIDENT CATEGORIZATION AND PRIORITIZATION

Incidents are categorized and prioritized.

Standards:

- Stride has established a framework for categorizing incidents based on their nature and impact.
    - Incidents are classified into categories such as malware, phishing, data breaches, denial of service, etc.
    - Each category has specific criteria and characteristics to facilitate accurate classification.
- Each incident is assessed to determine its potential impact on the organization.
    - Assessments consider factors such as data sensitivity, operational disruption, financial loss, and reputational damage.
    - Impact levels are defined (e.g., low, medium, high, critical) to standardize the assessment process.
- Incidents are prioritized based on their severity, urgency, and potential impact.
    - Prioritization criteria include the extent of the incident's impact, the criticality of the affected systems, and the potential for escalation.
    - Incidents are assigned priority levels (e.g., P1, P2, P3) to guide the response efforts.
- The Incident Response Team (IRT) is responsible for the initial categorization and prioritization of incidents.
    - The IRT uses predefined criteria and guidelines to ensure consistent and accurate categorization.
    - Regular reviews and updates to the categorization and prioritization criteria are conducted to adapt to evolving threats.
- Stride leverages automated tools to assist in the categorization and prioritization of incidents.

    - Tools analyze incident data and provide recommendations for categorization and prioritization.
    - Automation ensures quicker and more accurate incident handling, especially for high-volume incidents.
- Detailed documentation is maintained for each incident, including its categorization and prioritization.
    - Incident logs include the incident type, impact assessment, prioritization level, and actions taken.
    - Audit trails are maintained to track the decision-making process and ensure accountability.
- The categorization and prioritization processes are regularly reviewed and improved.
    - Post-incident reviews analyze the effectiveness of categorization and prioritization to identify areas for enhancement.
    - Feedback loops are established to incorporate insights from incident handling into the categorization and prioritization processes.
- Personnel involved in incident categorization and prioritization receive regular training.
    - Training sessions cover incident classification criteria, impact assessment methods, and prioritization techniques.
    - Simulated incident exercises are conducted to test the categorization and prioritization processes.
- Ensure that the categorization and prioritization processes comply with relevant legal, regulatory, and contractual requirements.
    - Procedures for preserving evidence and ensuring the chain of custody are documented and followed.
    - Incident management aligns with industry standards and regulatory guidelines.

References:

- CRI Profile v2.0: RS.MA-03

- CRI Profile v2.0: RS.MA-03.01
- CSF v1.1: RS.AN-4
- CSF v1.1: RS.AN-2

RS.MA-04: INCIDENT ESCALATION

Incidents are escalated or elevated as needed.

Standards:

- Stride has established a clear process for escalating incidents based on predefined criteria.
    - Incident severity levels are defined (e.g., low, medium, high, critical) to guide the escalation process.
    - Escalation criteria include factors such as the potential impact on operations, data integrity, confidentiality, and public perception.
    - The Incident Response Team (IRT) is responsible for assessing incidents and determining if escalation is required.
- Defined escalation paths and hierarchies ensure that incidents are elevated to the appropriate levels of authority.
    - Escalation paths specify the chain of command and decision-making hierarchy for different types of incidents.
    - Roles and responsibilities are clearly documented to avoid confusion during the escalation process.
- Timely and effective communication is essential during incident escalation.
    - Communication protocols are established to notify relevant stakeholders and decision-makers promptly.
    - Different communication channels are utilized based on the severity and urgency of the incident (e.g., email, phone, messaging apps).
- Specific triggers and thresholds are defined to determine when an incident requires escalation.

    - Triggers may include failure to resolve the incident within a certain timeframe, detection of additional threats, or significant impact on critical systems.
    - Thresholds are based on the severity and potential consequences of the incident.
- Comprehensive documentation and tracking of escalation activities are maintained to ensure accountability and traceability.
    - Incident logs include details of the escalation decision, stakeholders involved, and actions taken.
    - Audit trails are maintained to track the timeline and progression of the escalation process.
- The escalation and elevation processes are regularly reviewed and improved based on lessons learned.
    - Post-incident reviews analyze the effectiveness of the escalation process and identify areas for enhancement.
    - Feedback loops are established to incorporate insights from incident handling into the escalation processes.
- Personnel involved in the incident escalation receive regular training to ensure they are well-prepared.
    - Training sessions cover escalation criteria, communication protocols, and decision-making processes.
    - Simulated incident exercises are conducted to test the escalation and elevation processes.
- Ensure that the escalation processes comply with relevant legal, regulatory, and contractual requirements.
    - Procedures for preserving evidence and ensuring the chain of custody are documented and followed.
    - Incident escalation aligns with industry standards and regulatory guidelines.

References:

- CRI Profile v2.0: RS.MA-04

- CRI Profile v2.0: RS.MA-04.01
- CSF v1.1: RS.AN-2
- CSF v1.1: RS.CO-4

RS.MA-05: RECOVERY CRITERIA

The criteria for initiating incident recovery are applied.

Standards:

- Stride has established a clear framework for initiating incident recovery based on predefined criteria.
    - Recovery initiation criteria are documented to guide decision-making during the incident response process.
    - Criteria are based on factors such as incident severity, impact on operations, data integrity, and system availability.
- Each incident is assessed to determine if recovery efforts should be initiated.
    - Assessments consider the extent of damage, potential impact on critical systems, and the duration of the incident.
    - A detailed evaluation is conducted to determine the appropriate recovery actions.
- Specific roles and responsibilities are assigned for making decisions regarding the initiation of recovery efforts.
    - The Incident Response Team (IRT) or designated authority is responsible for assessing incidents and initiating recovery.
    - Decision-making authorities are clearly documented to avoid delays and confusion during the recovery process.
- The recovery plan is activated based on the predefined criteria and the assessment of the incident.
    - Activation criteria include factors such as the criticality of the affected systems, the extent of the damage, and the expected downtime.

    - The recovery plan outlines specific steps and actions to restore normal operations.

- Timely communication and notification are essential during the initiation of recovery efforts.
    - Communication protocols are established to notify relevant stakeholders and decision-makers.
    - Different communication channels are utilized based on the severity and urgency of the incident (e.g., email, phone, messaging apps).

- Comprehensive documentation and tracking of recovery initiation activities are maintained to ensure accountability and traceability.
    - Incident logs include details of the recovery initiation decision, stakeholders involved, and actions taken.
    - Audit trails are maintained to track the timeline and progression of the recovery process.

- The recovery initiation criteria and processes are regularly reviewed and improved based on lessons learned.
    - Post-incident reviews analyze the effectiveness of the recovery initiation process and identify areas for enhancement.
    - Feedback loops are established to incorporate insights from incidents handling into the recovery initiation criteria.

- Personnel involved in the initiation of recovery efforts receive regular training to ensure they are well-prepared.
    - Training sessions cover recovery initiation criteria, decision-making processes, and communication protocols.
    - Simulated incident exercises are conducted to test the recovery initiation processes.

- Ensure that the recovery initiation processes comply with relevant legal, regulatory, and contractual requirements.
    - Procedures for preserving evidence and ensuring the chain of custody are documented and followed.
    - Incident recovery aligns with industry standards and regulatory guidelines.

References:

- CIS Controls v8.0: 17.9
- CRI Profile v2.0: RS.MA-05
- CRI Profile v2.0: RS.MA-05.01